

TECHNOLOGY RISK ASSESSMENT, CONTROL ASSURANCE AND REMEDIATION PROGRAM

Project Charter

MapleCare Health Services

Prepared by Breck Agyekum | Technology Risk & GRC Analyst

Document status	Approved for portfolio use
Version	1.0
Review period	Q1 2026
Classification	Professional portfolio - simulated data

*Portfolio notice: MapleCare Health Services is fictional. All risks, controls, findings, evidence, dates and records are simulated.
No real patient, employee, client or company data is used.*

1. Engagement Overview

MapleCare Health Services is a fictional Canadian healthcare organization with approximately 150 employees. The organization relies on Microsoft 365, SharePoint, a patient records system, an HR management platform, employee endpoint devices, backup services and a third-party billing portal to support clinical, administrative and financial operations.

MapleCare processes sensitive patient, employee, billing and internal business information. Management requires a clearer view of material technology risks, existing controls, control gaps, remediation priorities and audit readiness.

This engagement establishes a structured technology risk assessment and control assurance program to support risk-based decision-making and management oversight.

2. Business Problem

MapleCare does not currently maintain a complete and centralized view of its technology and cybersecurity risks. Risk information is distributed across departments, control ownership is not always clearly defined, and evidence supporting key controls is not consistently maintained.

These conditions may limit management's ability to identify material risks, prioritize remediation, monitor control performance, assess third-party exposure, demonstrate audit readiness and report technology risk consistently to leadership.

3. Engagement Objective

The objective is to identify and assess MapleCare's key technology risks, document existing controls and control gaps, define appropriate control activities, and establish a structured approach for testing, remediation tracking and executive reporting.

The engagement will provide management with a documented view of critical systems and business processes, a prioritized technology risk register, clear control ownership and requirements, testing procedures and evidence expectations, accountable remediation actions and concise management reporting.

4. Scope

- | | |
|--------------------------------------|---|
| • Identity and access management | • Microsoft 365 and SharePoint security |
| • Patient-record access | • Employee onboarding and offboarding |
| • Privileged access | • Endpoint security |
| • Patch and vulnerability management | • Backup and recovery |
| • Incident response | • Security awareness |
| • Data classification | • Third-party and vendor risk |
| • Business continuity | • Risk governance |
| • Audit evidence management | |

5. Out of Scope

- | | |
|--|---|
| • Penetration testing | • Vulnerability scanning |
| • Source-code review | • Production-system changes |
| • Legal or regulatory opinions | • Formal certification or attestation |
| • Live access to real patient, employee or company | • Implementation of technical remediation actions |

data

6. Assessment Approach

1. Define the engagement scope, objectives and stakeholders.
2. Understand the business and technology environment.
3. Identify critical systems, processes, data, owners and dependencies.
4. Identify and assess technology, cybersecurity, privacy, resilience and third-party risks.
5. Document existing controls and control gaps.
6. Define recommended control activities.
7. Map controls to relevant NIST and ISO references.
8. Prepare control-testing procedures and evidence requirements.
9. Track findings and remediation actions.
10. Prepare executive risk reporting.

7. Risk Assessment Method

Risks will be evaluated using likelihood and business impact. Business impact will consider patient and service delivery, privacy and confidentiality, operational disruption, financial consequences, regulatory or contractual exposure and reputational harm.

8. Framework Alignment

The engagement uses NIST Cybersecurity Framework 2.0, NIST SP 800-53 Revision 5 and ISO/IEC 27001:2022 to support control design and assessment. NIST AI RMF and ISO/IEC 42001 concepts may be referenced where relevant. Framework mapping supports analysis and does not imply certification or formal compliance.

9. Stakeholders and Responsibilities

Stakeholder	Responsibility
Executive Sponsor	Provides oversight and supports major risk decisions.
Technology Risk Lead	Directs the assessment and reviews deliverables.
IT Manager	Provides technology information, control evidence and remediation ownership.
Operations Manager	Supports business-process assessment and continuity planning.
HR Manager	Supports onboarding, offboarding, training and access-control reviews.
Finance Manager	Supports billing-vendor and financial-process assessment.
Clinic Manager	Supports patient-record access and clinical-system assessment.
Control Owners	Validate controls, provide evidence and manage remediation actions.

10. Engagement Role

- Coordinate assessment activities

- Document the business and technology environment
- Maintain the asset and process inventory
- Develop the technology risk register
- Document existing controls and control gaps
- Prepare the Risk and Control Matrix
- Define testing procedures and evidence requirements
- Track remediation actions
- Prepare management reporting
- Maintain traceability between risks, controls, evidence and actions

11. Deliverables

#	Deliverable	Purpose
1	Project Charter	Defines objective, scope, stakeholders, approach and governance.
2	Business and Technology Profile	Documents the operating environment, systems, data and dependencies.
3	Asset and Process Inventory	Identifies important systems, processes, ownership, sensitivity and criticality.
4	Risk Register	Records and prioritizes technology and cybersecurity risks.
5	Risk and Control Matrix	Links risks to controls, owners, evidence, testing procedures and frameworks.
6	Control Testing and Evidence Package	Assesses control design and operating effectiveness.
7	Remediation Tracker	Tracks findings, owners, target dates, evidence and validation.
8	Executive Dashboard and Report	Summarizes risk exposure, control effectiveness and remediation progress.

12. Governance and Review

Risks and control descriptions will be validated with relevant owners. High and critical risks will be escalated for management review. Evidence requests and testing conclusions will be documented. Remediation actions will include accountable owners and target dates. Completed actions will require closure evidence and retesting before final closure.

13. Assumptions

Stakeholders provide complete and accurate information. System and process owners are available for review. Relevant policies, reports and control evidence can be provided. Conclusions are based on information available during the assessment. Fictional data and scenarios are used for portfolio demonstration.

14. Limitations

This engagement is a portfolio-based simulation and does not represent an audit, certification, legal review or formal assurance opinion. No real patient, employee, client or company data is used.

15. Success Measures

Critical systems and processes are documented; material risks are identified and prioritized; ownership is assigned; controls and gaps are documented; testing procedures are prepared; remediation actions are tracked; and management reporting clearly communicates risk exposure and priorities.

16. Approval

Role	Name	Status	Date
Executive Sponsor	Simulated	Pending	
Technology Risk Lead	Breck Agyekum	Prepared	
IT Manager	Simulated	Pending	
Operations Manager	Simulated	Pending	

Portfolio Notice

MapleCare Health Services is a fictional Canadian healthcare organization created for professional portfolio demonstration. All systems, risks, controls, findings and records are simulated.